

Khảo sát thị trường — Phần mềm nhận diện lừa đảo (app chạy ngầm trên mobile)

1. Khảo sát web / app trên thị trường

1.1. nTrust — Hiệp hội An ninh mạng quốc gia (NCA), Việt Nam

Là gì. App phòng chống lừa đảo miễn phí do NCA phát hành 30/7/2024, có trên cả App Store và Google Play. Định vị là "tấm khiên" cho người dùng phổ thông, kiểm tra *trước khi* giao dịch. Trang chủ: ntrust.vn.

Cách hoạt động (kỹ thuật & dữ liệu).

- Lỗi là **tra cứu blacklist tập trung** trên kho dữ liệu **hơn 1 triệu bản ghi** gồm số điện thoại, số tài khoản, website lừa đảo.
- Nguồn dữ liệu được xác minh từ **Bộ Công an, Bộ TT&TT, Ngân hàng Nhà nước** và các tổ chức thành viên hiệp hội — cập nhật liên tục, bổ sung thêm từ cộng đồng.
- Chức năng chính: kiểm tra **số điện thoại, địa chỉ web/link, số tài khoản ngân hàng, quét mã độc** (rà soát ứng dụng đã cài), **kiểm tra mã QR**, và **chặn cuộc gọi lừa đảo/làm phiền**.
- Đăng nhập nhẹ: nhập tên + số điện thoại, nhận OTP.

Trải nghiệm chạy ngầm. Trên iOS, chặn cuộc gọi hoạt động qua *Call Directory Extension* (Cài đặt → Điện thoại → Chặn cuộc gọi & ID → bật "nTrust"), tức app đăng ký danh sách số với hệ điều hành và chặn ngầm mà không cần mở app. Đây là mô hình ngầm "đúng chuẩn iOS" đáng học.

Bài học cho đồ án.

- Uy tín đến từ **nguồn dữ liệu cơ quan nhà nước** — đây là lợi thế niềm tin mà bản khóa luận khó có; cần thay bằng dữ liệu mẫu + minh bạch quy trình.
- Kiến trúc "nhiều loại đầu vào, một cơ chế tra cứu blacklist + cộng đồng" gần như trùng khớp với hướng đồ án → nên định vị khác biệt bằng **rule engine giải thích được** thay vì chỉ trả về có/không.

1.2. ChongLuaDao.vn — tổ chức phi lợi nhuận, Việt Nam

Là gì. Tổ chức chống lừa đảo phi lợi nhuận hoạt động từ 12/2020 (CEO Ngô Minh Hiếu / Hieu Minh Ngo). Trang chủ: chongluadao.vn.

Cách hoạt động (đa kênh — điểm rất đáng học).

- **Tiện ích trình duyệt** trên Chrome, Microsoft Edge, Cốc Cốc, Brave, Firefox ([Chrome Web Store](#)).
- **PWA** cài trên iPhone/Android (Add to Home Screen) thay cho app native — cách tiếp cận nhẹ, không qua kho ứng dụng ([hướng dẫn](#)).
- **Tích hợp ở tầng DNS:** OpenDNS, NextDNS, FlashStart — cảnh báo/chặn *mà không cần cài gì*, kể cả bật DNS-over-HTTPS. Đây là cách "chạy ngầm" toàn hệ thống.
- **Chia sẻ blocklist** cho nhiều phần mềm diệt virus (Kaspersky, Avira, Avast, ESET, Sophos, Trend Micro, CyRadar) và VirusTotal.
- Công nghệ: **Machine Learning phát hiện phishing** + báo cáo cộng đồng. Mã nguồn mở tại GitHub tổ chức [@7zones](#) (repo [chongluadao-extension](#), [Phishing-detection-ML](#)).
- Nền tảng AI mới: ai.chongluadao.vn.

Bài học cho đồ án.

- Mô hình **phân phối đa điểm chạm** (extension + DNS + API cho đối tác) đáng tham khảo cho phần "hướng phát triển": không nhất thiết phải là 1 app.
- **Mã nguồn mở** là một cách tạo niềm tin (xem mục 4).

1.3. Tín Nhiệm Mạng — NCSC / NCA, Việt Nam

Là gì. Hệ sinh thái *cấp chứng nhận tin cậy* về an toàn thông tin, thuộc Trung tâm Giám sát an toàn không gian mạng quốc gia (NCSC). Trang chủ: tinnhiemmang.vn. Đây là hệ thống **vừa là nguồn dữ liệu vừa là mô hình niềm tin**, nên liên quan trực tiếp cả câu hỏi "làm sao để người ta tin tưởng".

Cách hoạt động.

- **Tra cứu số tài khoản ngân hàng** với 3 trạng thái: *lừa đảo / an toàn / đang xác minh*, kèm chủ tài khoản, ngân hàng, và cho phép bình luận/vote ([tra cứu tài khoản](#)).
- **Danh sách đen website/mạng xã hội giả mạo**, lọc theo *tình trạng* (đang chờ / đang xác minh / đang xử lý / đã xử lý) và *loại* ([danh sách đen](#)).

- **Báo cáo thông tin giả mạo** với form + hình ảnh bằng chứng → quy trình kiểm duyệt.
- **Gán nhãn tín nhiệm Website** (gói Basic/Premium): tổ chức đăng ký, nhận bộ tiêu chí ATTT, cung cấp bằng chứng + đánh giá bên thứ ba (gói nâng cao), NCA thẩm định rồi cấp nhãn (dịch vụ cho website).

Bài học cho đồ án.

- Mô hình **trạng thái báo cáo có vòng đời** (chờ → xác minh → xử lý → đã xử lý) là mẫu trực tiếp cho bảng **ScamReport** trong đồ án.
- Ý tưởng **"nhãn tín nhiệm/whitelist"** giúp giảm cảnh báo sai — nên đưa vào rule engine như tín hiệu điểm âm.

1.4. Whoscall (Gogolook, Đài Loan)

Là gì. App nhận diện & chặn cuộc gọi/tin nhắn hàng đầu châu Á, dựa trên AI + cộng đồng toàn cầu (App Store, Google Play). Nhà phát triển Gogolook là thành viên tích cực của liên minh chống lừa đảo toàn cầu (GASA).

Cách hoạt động & tính năng nổi bật.

- **Caller ID & Blocker:** nhận diện số lạ và tự chặn cuộc gọi lừa đảo theo thời gian thực.
- **Smart SMS Assistant:** lọc tin nhắn phishing trước khi tới người dùng.
- **Check:** xác minh **số điện thoại, URL và cả ảnh chụp màn hình** (hàm ý OCR) trong một chỗ.
- **Gamification cộng đồng:** hệ thống *Badge* và *Mission Board* — người dùng báo cáo/điểm danh để nhận điểm, nuôi dữ liệu cho mạng lưới.

Trải nghiệm chạy ngầm. Hiện thị Caller ID overlay ngay khi có cuộc gọi → phải cấp quyền hiển thị trên ứng dụng khác, đọc nhật ký cuộc gọi/danh bạ. Đây là điểm đánh đổi quyền riêng tư kinh điển (xem mục 5).

Bài học cho đồ án. Gamification + huy hiệu là cách **tăng chất lượng và số lượng báo cáo cộng đồng** — có thể mô hình hóa bằng "điểm uy tín người báo cáo" đã nêu trong tài liệu tham khảo của nhóm.

1.5. Truecaller

Là gì. App nhận diện số gọi đến & chặn spam với cơ sở dữ liệu cộng đồng khổng lồ, phổ biến ở Nam Á/Đông Nam Á.

Điểm phân tích. Sức mạnh nằm ở *quy mô mạng lưới* (càng nhiều người dùng, database càng lớn). Nhưng bị cộng đồng lo ngại vì **thu thập danh bạ** để dựng dữ

liệu người dùng → minh họa rõ mâu thuẫn *hiệu quả mạng lưới* ↔ *quyền riêng tư*.
Với đồ án, đây là lời cảnh báo: không nên tải toàn bộ danh bạ/nội dung nhạy cảm lên server.

1.6. Trend Micro ScamCheck

Là gì. App chống lừa đảo của Trend Micro — một hãng bảo mật lớn ([App Store](#)).

Tính năng. Call blocker, lọc SMS, **phát hiện video call giả (deepfake)**, chặn website độc hại; mô hình thương mại (free trial 30 ngày rồi thu phí).

Bài học. Niềm tin đến từ **thương hiệu bảo mật lâu năm** + tính năng đón đầu xu hướng (deepfake). Đồ án có thể nêu "phát hiện nội dung AI/deepfake" ở phần hướng phát triển.

1.7. ScamAdviser

Là gì. Công cụ đánh giá độ tin cậy website ("Trust Score"), phục vụ ~2,5–4,5 triệu người dùng/tháng, thành lập 2012 ([scamadviser.com](#)).

Cách hoạt động (kỹ thuật).

- **Trust Score** cân bằng *tín hiệu tích cực vs tiêu cực* từ **hơn 40 nguồn dữ liệu độc lập**, chia 5 nhóm; không một yếu tố đơn lẻ nào quyết định điểm ([giải thích thuật toán](#)). Tín hiệu gồm: tuổi tên miền, vị trí máy chủ, SSL, hiện diện mạng xã hội, đánh giá Trustpilot, các site cùng server...
- **App di động** dùng **Android VpnService** để kiểm tra URL và cảnh báo web rủi ro *theo thời gian thực* — nói rõ đây **không phải VPN thật, không đổi vị trí** ([Google Play](#)).
- Cung cấp **white-label** cho doanh nghiệp và chia sẻ dữ liệu với 50+ đối tác (cơ quan thực thi pháp luật, bảo vệ thương hiệu).

Rủi ro/đạo đức. ScamAdviser bị một số chủ website tố cáo chấm điểm **sai lệch / gây hại SEO** và nghi vấn mô hình thu phí. Bài học: hệ thống chấm điểm tự động **phải có cơ chế khiếu nại, chỉnh sửa, và không tuyên bố tuyệt đối** — đúng như phần "phạm vi an toàn & đạo đức" của nhóm.

1.8. Google Safe Browsing & Android Scam Detection

Là gì. Hạ tầng bảo vệ ở tầng hệ điều hành/trình duyệt của Google.

Cách hoạt động (kỹ thuật).

- **Safe Browsing API:** client kiểm tra URL với danh sách site nguy hiểm (phishing/deceptive, malware, unwanted software) qua `urls.search` hoặc

`hashes.search`; v4 dùng `threatMatches.find` (tối đa 500 URL/request) ([tài liệu](#)). **Chỉ dùng phi thương mại**; bản thương mại là **Web Risk API**.

- **Hash-based lookup**: gửi *tiền tố hash* thay vì URL đầy đủ → bảo vệ quyền riêng tư — kỹ thuật rất đáng học cho app ngầm.
- **Enhanced Safe Browsing**: kiểm tra thời gian thực nâng cao.
- **Android Scam Detection in Messages**: AI **chạy on-device** phát hiện hội thoại lừa đảo trên SMS/MMS/RCS ngay cả sau tin nhắn đầu ([Google blog](#)); **Pixel Scam Detection** cho cuộc gọi cũng chạy on-device.

Bài học cho đồ án. Hai ý tưởng vàng: **(a) tra cứu bằng hash tiền tố** để không lộ URL người dùng; **(b) xử lý on-device** để bảo vệ dữ liệu — nên trình bày như định hướng "privacy-by-design".

1.9. Scameter+ (CyberDefender, Cảnh sát Hồng Kông)

Là gì. App phát hiện web phishing/scam chạy nền qua **VPN tunnel cục bộ** ([Google Play](#)).

Cách hoạt động (mô hình lý tưởng cho "app chạy ngầm bảo vệ riêng tư").

- Đẩy **danh sách domain phishing** đã xác minh ở dạng hash về máy **mỗi ngày**, lưu thành database cục bộ.
- VPN tunnel **so sánh domain ngay trên máy**, phát cảnh báo khi phát hiện.
- Cam kết: VPN chỉ chạy cục bộ, **không kết nối remote, không lưu/không gửi lịch sử duyệt** hay dữ liệu cá nhân.

Bài học cho đồ án. Đây là hình mẫu tốt nhất cho câu hỏi "chạy ngầm nhưng vẫn giữ niềm tin": *lọc cục bộ + dữ liệu hashed + minh bạch không thu thập*.

1.10. Nhóm app "quét thông báo" (Vizillo AI, Malwarebytes Scam Guard...)

Cách hoạt động. Dùng **Notification Access** để quét nội dung thông báo (SMS, WhatsApp, Gmail) và cảnh báo link lừa đảo *trước khi người dùng bấm*; phân tích cục bộ trên máy ([Vizillo AI](#)). Malwarebytes có "Scam Guard" đa nền tảng.

Bài học. Notification Listener là kênh "chạy ngầm" mạnh nhưng nhạy cảm — phải khai báo minh bạch và xử lý cục bộ (xem mục 5).

<details><summary>Bảng tổng hợp nhanh 10 web/app (bấm để mở)</summary>

Sản phẩm	Xuất xứ	Loại đầu vào	Cơ chế lỗi	Chạy ngầm kiểu gì
nTrust	VN (NCA)	SĐT, link, STK, QR, app	Blacklist tập trung + cộng đồng	Call directory extension (iOS)
ChongLuaDao	VN (NPO)	URL/web	ML + báo cáo + DNS/extension	DNS toàn hệ thống, extension, PWA
Tín Nhiệm Mạng	VN (NCSC)	STK, website	Blacklist + nhãn tín nhiệm + vote	Web tra cứu (không ngầm)
Whoscall	Đài Loan	SĐT, SMS, URL, ảnh	AI + cộng đồng + gamification	Caller ID overlay real-time
Truecaller	Thụy Điển/Ấn	SĐT, SMS	Database cộng đồng lớn	Caller ID overlay
Trend Micro ScamCheck	Nhật/Mỹ	Call, SMS, web, video	AI hằng bảo mật + deepfake	Call/SMS filter nền
ScamAdviser	Hà Lan	URL/website	Trust Score 40+ tín hiệu	Android VpnService (local)
Google Safe Browsing	Mỹ	URL	Hash lookup + list, on-device	Tầng OS/trình duyệt
Scameter+	Hồng Kông	Domain	Hash list cục bộ + local VPN	Local VPN, hashed, không remote
Vizillo / Malwarebytes	Mỹ	Thông báo/SMS/mail	Notification scan cục bộ	Notification Listener

</details>

2. Tổ chức & nền tảng cộng đồng

2.1. APWG — Anti-Phishing Working Group

- **Là gì:** Liên minh quốc tế chống tội phạm điện tử, thành lập 2003; hơn 2.000 tổ chức thành viên (ngành, thực thi pháp luật, chính phủ, đại học). Cố vấn cho EU, Council of Europe, UNODC, OECD, OSCE. Trang chủ: apwg.org.
- **Giá trị cho đồ án:** Bộ **Phishing Activity Trends Report** hàng quý là nguồn số liệu học thuật cực tốt để viết phần "tổng quan/thực trạng" — ví dụ Q1/2025 ghi nhận **1.003.924 vụ phishing**, QR-code phishing tăng mạnh ([trends](#)

reports). APWG cũng có chương trình nghiên cứu và eCrime Fighters Scholarship.

2.2. GASA — Global Anti-Scam Alliance

- **Là gì:** Mạng lưới toàn cầu chống lừa đảo, trụ sở The Hague (Hà Lan), phi lợi nhuận; quy tụ chính phủ, cơ quan bảo vệ người tiêu dùng/tài chính, thực thi pháp luật, công ty công nghệ. Trang chủ: gasa.org.
- **Giá trị:** Báo cáo *Global State of Scams* (hợp tác Feedzai, khảo sát ~58.000 người) — nguồn số liệu thị trường mạnh. Có chương trình *Scam Fighter Awards*, các *Chapter* theo khu vực.

2.3. PhishTank (vận hành bởi Cisco Talos)

- **Là gì:** Kho dữ liệu phishing cộng đồng miễn phí — ai cũng có thể **submit / verify / track / share**; do Cisco Talos Intelligence Group vận hành (phishtank.org).
- **Kỹ thuật/API:** API mở miễn phí, gửi HTTP POST tới `checkurl.phishtank.com/checkurl/` với `url` (urlencoded/base64) và `format` (xml/php/json), kèm `app_key` để tăng rate limit ([API info](#)). Có public dump cập nhật hàng giờ.
- **Bài học:** Đây là mẫu chuẩn cho luồng **user report** → **verify** → **công bố blacklist** mà đồ án nên mô phỏng (dùng dữ liệu mẫu).

2.4. VirusTotal (Google/Chronicle)

- **Là gì:** Tổng hợp phân tích URL/domain/file từ nhiều engine bảo mật + **community reputation** (vote của người dùng có uy tín).
- **Bài học:** Ý tưởng **gom nhiều tín hiệu với trọng số** thay vì một luật; nhưng nghiên cứu học thuật cảnh báo kết quả nhiều scanner có thể *nhiều/bất đồng* → cần trọng số & giải thích, tránh majority-vote ngây thơ.

2.5. Các đầu mối tại Việt Nam

- **NCA — Hiệp hội An ninh mạng quốc gia:** đơn vị sau nTrust; đại diện cho hướng "dữ liệu nhà nước + cộng đồng".
- **NCSC — Trung tâm Giám sát an toàn không gian mạng quốc gia:** vận hành Tín Nhiệm Mạng và tiếp nhận hàng trăm báo cáo lừa đảo/tuần.
- **[ChongLuaDao.vn](https://chonglua dao.vn):** nền tảng cộng đồng phi lợi nhuận, chia sẻ blacklist mở.

3. Hội nghị chuyên ngành (kèm link)

Đây là các sự kiện để trích dẫn "đề tài có tính thời sự" và tìm paper/tài liệu. Sắp theo mức liên quan.

Hội nghị	Đơn vị tổ chức	Trọng tâm	Link
APWG eCrime (Symposium on Electronic Crime Research)	APWG	Hội nghị học thuật <i>peer-reviewed</i> về tội phạm điện tử; eCrime 2026 là lần thứ 21 (Lisbon, 2–6/11/2026)	apwg.org/events/ecrime2026
Global Anti-Scam Summit (GASS)	GASA	Chuỗi summit khu vực (Europe/Asia/America); quy tụ chính phủ, tài chính, công nghệ	gasa.org/events
Global Fraud Summit	UNODC + INTERPOL	Cấp liên chính phủ về gian lận xuyên quốc gia (16–17/3/2026, Vienna)	unodc.org/.../global-fraud-summit
FINRA Financial Crimes & Cybersecurity Conference	FINRA	Phát hiện gian lận, AML, bảo vệ nhà đầu tư	finra.org/.../2026
InfoSec World	CyberRisk Alliance	An ninh mạng tổng quát (Orlando, 10/2026)	infosecworldusa.com
Cổng tổng hợp sự kiện	InfoSec-Conferences	Index 4.000+ hội nghị bảo mật để lọc theo chủ đề	infosec-conferences.com

4. Chứng chỉ bảo mật & "Làm sao để người dùng tin tưởng?"

"*làm sao để người ta tin mình?*" — với một app xử lý dữ liệu nhạy cảm và chạy ngầm, niềm tin đến từ **3 lớp**: (A) chứng nhận/khung tuân thủ, (B) minh bạch dữ liệu trên store, (C) tuân thủ pháp luật VN. *OWASP MASVS/MASTG thuộc phần bạn khác nên chỉ nhắc để dẫn chiếu.*

4.1. Chứng nhận & khung tuân thủ tổ chức

ISO/IEC 27001 (ở VN: TCVN ISO/IEC 27001:2019).

- Tiêu chuẩn quốc tế cho **Hệ thống quản lý an toàn thông tin (ISMS)**: một *tổ chức chứng nhận được công nhận* xác nhận doanh nghiệp đã thiết lập/duy trì ISMS đạt chuẩn (là **chứng chỉ** đúng nghĩa, có hiệu lực theo chu kỳ đánh giá).
- Ở VN đã có các đơn vị tư vấn/cấp chứng nhận (TÜV SÜD, TÜV NORD, TÜV Rheinland, BVC...) và nhiều doanh nghiệp CNTT đạt chứng chỉ. Phù hợp để nêu như "đích tuân thủ" nếu sản phẩm thương mại hóa.

SOC 2 (AICPA).

- Không phải "chứng chỉ" mà là **báo cáo kiểm toán/attestation** theo 5 Trust Services Criteria (security, availability, processing integrity, confidentiality, privacy).
- **Type I** = tại một thời điểm; **Type II** = đánh giá vận hành qua nhiều tháng (đảm bảo mạnh hơn). Đặc biệt phù hợp SaaS/app — dùng làm "bằng chứng" cho khách hàng doanh nghiệp.

So sánh nhanh để đưa vào báo cáo:

Tiêu chí	ISO/IEC 27001	SOC 2
Bản chất	Chứng chỉ (certification)	Báo cáo attestation của kiểm toán
Phạm vi	ISMS toàn tổ chức	Theo Trust Services Criteria, phạm vi tự định
Thời gian đánh giá	Cửa sổ ngắn (vài ngày)	Type II kéo dài nhiều tháng
Phổ biến nhất ở	Toàn cầu, gồm VN/EU/châu Á	Bắc Mỹ, ngành SaaS

Với **khóa luận** (không phải doanh nghiệp), không thể thực sự đạt các chứng chỉ này. Cách xử lý học thuật đúng đắn: **thiết kế hệ thống theo các control của ISO 27001 / tiêu chí SOC 2** (mã hóa, phân quyền, nhật ký/audit log, quản lý rủi ro, secure SDLC) và trình bày như "định hướng tuân thủ", thay vì tuyên bố đã được chứng nhận.

4.2. Niềm tin ở tầng cửa hàng ứng dụng (rất quan trọng vì app chạy ngầm)

Google Play Data Safety section.

- Bắt buộc mọi app khai báo **thu thập gì, chia sẻ gì, bảo vệ ra sao** trước khi người dùng cài; hiển thị công khai trên trang store ([Play Console Help](#)).
- Gồm 3 phần: *Data Shared, Data Collected, Security Practices* (mã hóa khi truyền, cho phép xóa dữ liệu...). Từ 20/7/2022, **privacy policy + form Data Safety hợp lệ là bắt buộc**; khai sai có thể bị gỡ app.
- Apple có bản tương đương là **Privacy Nutrition Labels / App Privacy**.

Vì sao then chốt: Một app *chạy ngầm* xin quyền VPN/Notification/Accessibility sẽ khiến người dùng nghi ngại. Data Safety trung thực + chính sách quyền riêng tư rõ ràng chính là "chứng chỉ niềm tin" thực tế nhất ở phân khúc này.

4.3. Tuân thủ pháp luật Việt Nam

Nghị định 13/2023/NĐ-CP về Bảo vệ dữ liệu cá nhân (hiệu lực 01/7/2023).

- Văn bản pháp lý đầu tiên & toàn diện của VN về dữ liệu cá nhân; phân biệt **dữ liệu cá nhân cơ bản** và **nhạy cảm**, quy định quyền của chủ thể dữ liệu và nghĩa vụ khi thu thập/lưu trữ/sử dụng/chuyển giao ([toàn văn](#)).
- Đồ án nên bám các nguyên tắc: **chỉ thu thập tối thiểu, có sự đồng ý, mã hóa, không lưu OTP/mật khẩu/số thẻ** — đúng phạm vi đạo đức nhóm đã đặt ra.

Nhãn Tín Nhiệm Mạng (NCA): một dạng "trust label" nội địa mà website/tổ chức VN có thể xin cấp để chứng minh uy tín — có thể tham chiếu như cơ chế niềm tin bản địa.

4.4. Cơ chế tạo niềm tin không cần chứng chỉ (áp dụng ngay được)

- **Xử lý cục bộ (on-device) + tra cứu hash** như Google Safe Browsing/Scameter+ → "không nhìn thấy" dữ liệu người dùng.
- **Mã nguồn mở** như ChongLuaDao → ai cũng kiểm chứng được.
- **Giải thích được (explainability):** trả về *điểm rủi ro + lý do + bằng chứng + khuyến nghị*, không phán "chắc chắn lừa đảo".
- **Cơ chế khiếu nại/chỉnh sửa** cho đối tượng bị gán cờ (bài học từ tranh cãi ScamAdviser).
- **Kiểm duyệt cộng đồng có vòng đời trạng thái + điểm uy tín người báo cáo** (từ Tín Nhiệm Mạng, PhishTank, Whoscall).

5. Góc nhìn người dùng: một app chạy ngầm trên điện thoại

Phần này trả lời trực tiếp yêu cầu "viết dưới góc nhìn người dùng — app chạy ngầm trên mobile": app cần cơ chế nào để *thấy* dữ liệu mà bảo vệ người dùng, và cái giá niềm tin phải trả.

5.1. Ba cơ chế "chạy ngầm" phổ biến & đánh đổi

(a) VpnService cục bộ (local VPN) — lọc URL/DNS.

- Android cho phép app tạo *virtual network interface*, nhận từng gói IP để lọc; app đối chiếu domain với blacklist rồi cảnh báo/chặn ([Android VPN docs](#)).
- Ưu điểm: bảo vệ **toàn bộ lưu lượng**, chạy nền liên tục (always-on). Nhược điểm: người dùng thấy biểu tượng "VPN" gây lo ngại → **phải nói rõ "local, không định tuyến ra server"** (đúng cách ScamAdviser và Scameter+ làm).

(b) Notification Listener — quét thông báo SMS/chat.

- Đọc nội dung thông báo để bắt link/OTP lừa đảo trước khi bấm. Rất mạnh nhưng **cực nhạy cảm** (thấy cả nội dung riêng tư) → chỉ nên **phân tích cục bộ**, không upload.

(c) Call Screening / Caller ID (chặn cuộc gọi).

- iOS dùng *Call Directory Extension* (như nTrust), Android dùng *CallScreeningService/Role*. App đăng ký danh sách số với OS và chặn ngầm — mô hình an toàn vì OS kiểm soát.

5.2. Cảnh báo lớn: Accessibility Service — nên tránh

- Nhiều app đòi **Accessibility Service** để đọc màn hình/tự bấm. Nhưng đây chính là quyền **bị malware ngân hàng lạm dụng** nhiều nhất: đọc mật khẩu/OTP, tự động chuyển tiền, chặn gỡ cài đặt (Cloak & Dagger) — theo phân tích của Pradeo, Guardsquare, HackTricks.
- Khuyến nghị cho đồ án:** *không* xây tính năng dựa trên Accessibility. Nếu bắt buộc để cập, nêu như "rủi ro cần phát hiện & phòng chống", vì một app chống lừa đảo mà xin quyền của malware sẽ **phá vỡ niềm tin**.

5.3. Hành trình người dùng lý tưởng (đề xuất cho đồ án)

- Cài app → màn hình onboarding **giải thích rõ từng quyền** và "chúng tôi không thu thập gì".

2. Bật *bảo vệ nền* (local VPN lọc domain hashed + chặn cuộc gọi từ blacklist).
3. Khi gặp link/tin nhắn/cuộc gọi/QR nghi ngờ → **cảnh báo tức thời** kèm *điểm rủi ro + lý do + khuyến nghị* (không bấm, không nhập OTP, không chuyển tiền).
4. Người dùng có thể **tra cứu chủ động** (dán link, số ĐT, số TK) và **gửi báo cáo** vào hàng đợi kiểm duyệt.
5. Mọi phân tích nhạy cảm ưu tiên **on-device**; chỉ gửi server phần tối thiểu (ví dụ hash tiền tố).

6. Kết luận & khuyến nghị định vị đồ án

- **Khoảng trống để khai thác:** phần lớn app VN mạnh về *blacklist tra cứu* (nTrust, Tín Nhiệm Mạng) nhưng ít **giải thích vì sao rủi ro**; app quốc tế mạnh về AI/quy mô nhưng không tối ưu bối cảnh VN. Đồ án nên định vị: **nền tảng đa nguồn (link + form + tin nhắn + SĐT + STK + báo cáo) với Rule Engine giải thích được, ưu tiên xử lý cục bộ & minh bạch dữ liệu**.
- **Ba trụ niềm tin để trình bày trước hội đồng:** (1) *privacy-by-design* (on-device + hash lookup, học Google/Scameter+); (2) *minh bạch* (Google Play Data Safety + tuân thủ Nghị định 13 + mã nguồn mở như ChongLuaDao); (3) *công bằng* (explainability + cơ chế khiếu nại, tránh vết xe đổ ScamAdviser).
- **Tính thời sự để trích dẫn:** số liệu APWG (>1 triệu vụ phishing/Q1-2025, QR phishing tăng), báo cáo GASA *State of Scams*, xu hướng deepfake (Trend Micro) và scam detection on-device (Android/Pixel).

phần **OWASP (MASVS/MASTG, kiểm thử bảo mật mobile)** đã có thành viên khác đảm nhận

Nguồn tham khảo chính

- Việt Nam: ntrust.vn · chongluadao.vn · tinnhiemmang.vn · [Nghị định 13/2023](#)
- App quốc tế: [Whoscall](#) · [Trend Micro ScamCheck](#) · [ScamAdviser](#) · [Scameter+](#)
- Tổ chức/dữ liệu: [APWG](#) · [GASA](#) · [PhishTank](#) · [Google Safe Browsing](#)
- Hội nghị: [APWG eCrime 2026](#) · [GASS](#) · [UNODC-INTERPOL Global Fraud Summit](#)
- Chứng nhận/niềm tin: [Play Data Safety](#) · [Android VPN](#)